

Every LoB ships Separately, every time.

OCM is the shared standard. Each LoB still ships — on the same model.

Open Component Model — open source, NeoNephos Foundation. Stewarded by SAP.



WHY NOW

Compliance and sovereignty are given. Our strategic position is a choice.

ECOSYSTEM VELOCITY

The peer ecosystem is converging.
The biggest contributor shapes the standard.

THE WINDOW

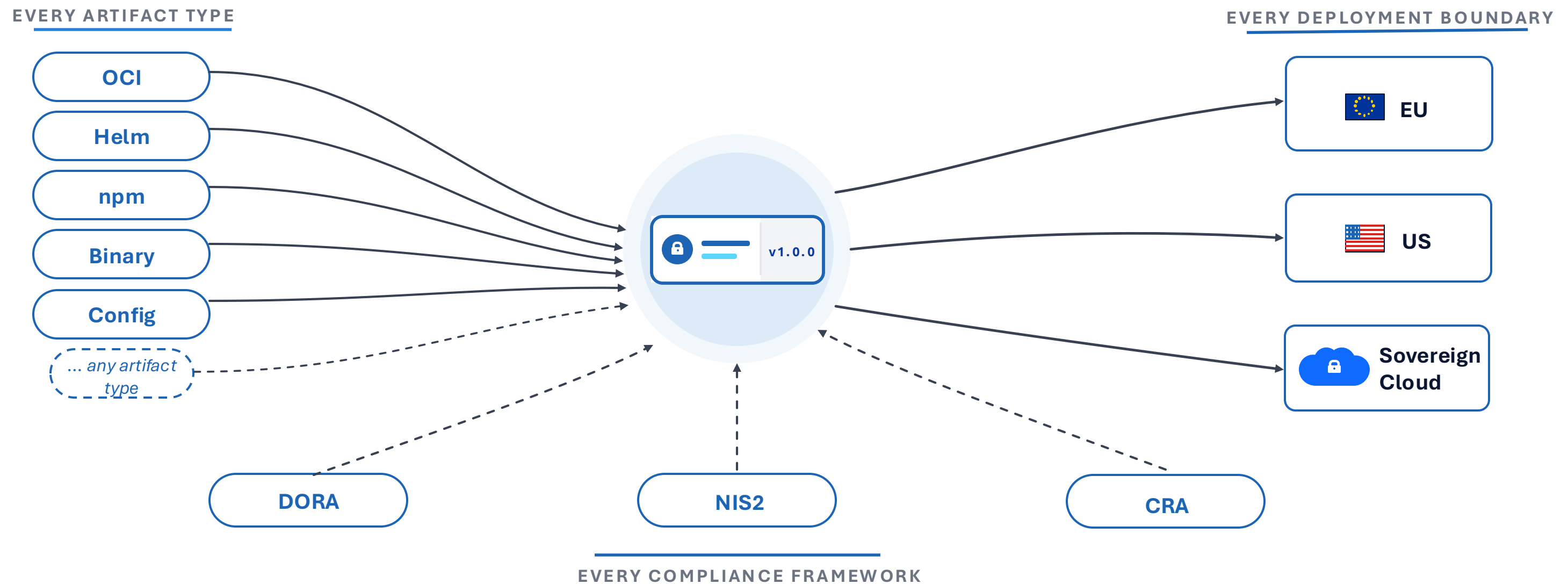
The rails are being laid now.
Late entrants pay migration cost.

DISINVESTMENT COST

Walking away costs more than staying.
The standard gets shaped without us.

THE ANSWER

Meet OCM. One identity, every boundary.



THE SHIFT

SBOM lists. SBOD delivers.

- SBOM - what's inside your software. Built for inventory.
- A Software Bill of Delivery (SBOD) - what you delivered, how to verify, transport, operate. Built for delivery.
- SBOD contains SBOM. OCM doesn't replace your SBOM tooling — OCM gives the SBOM an envelope.
- SBOD is the category SAP defined. Now governed through NeoNephos.

THE SHIFT — SBOM INSIDE SBOD

What the envelope holds.

SOFTWARE BILL OF DELIVERY (SBOD)

`github.com/acme/webshop:v1.0.0`

Location-independent name. Same identity, every registry.



ARTIFACTS

What you delivered. How to verify it · how to operate it.



Docker Images



Helm Charts



Kubernetes Deployment Manifests



Configuration Files



SBOM



SIGNATURE

One digest covers all.

HOW OCM COMPOSES

Composes around your existing stack.

SIGNING

You sign artifacts.
OCM signs the release.

TRANSPORT

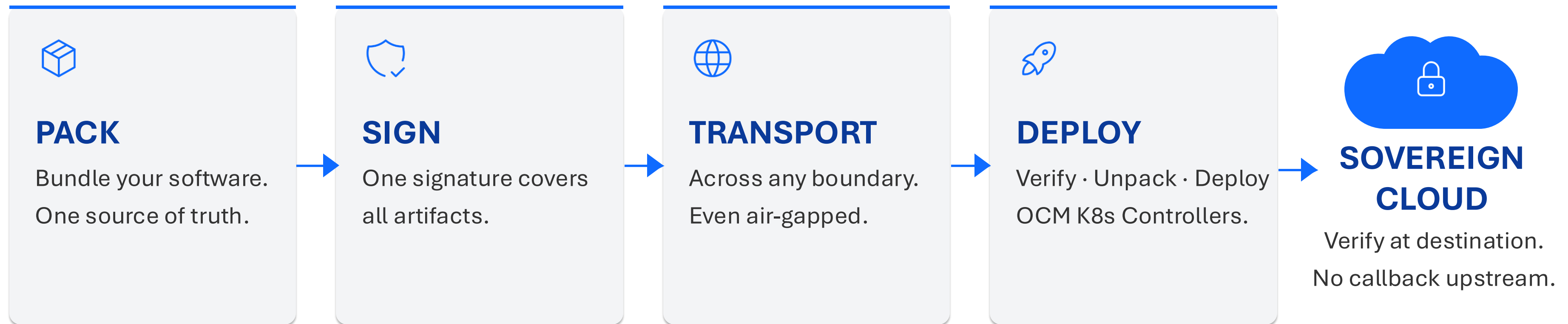
Your registries differ.
OCM moves the release across them.

COMPLIANCE

Your scanners see one artifact at a time.
OCM correlates findings to the release.

OCM IN ONE PICTURE

Pack · Sign · Transport · Deploy



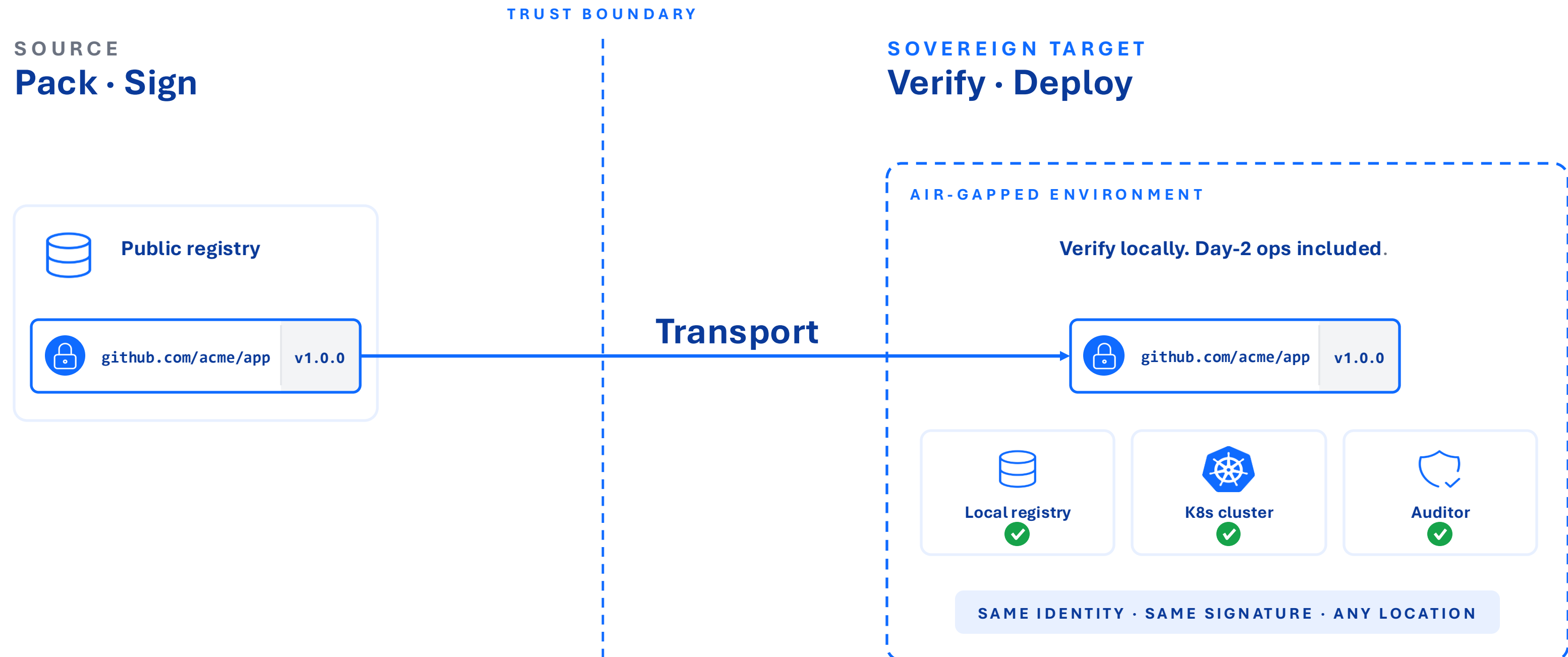
SOVEREIGN-READY

Trust, but verify.

- Identity — location-independent. The component carries its name regardless of registry.
- Signatures — location-independent. Sign once at source, verify anywhere downstream. No callback upstream.
- Transfer — self-contained. Every artifact travels with the component.
- Day-2 ops — happen inside the boundary. Subscribe, pull upgrades, scale across regions. Still no callback.

SOVEREIGN-READY — AIR-GAP

Trust travels with the component.



SCAN

Compliance as a system property — not a quarterly retrofit.

- Open Delivery Gear (ODG) — the OCM compliance automation engine, built on the same primitives.
- The Compliance Dashboard — every component, every finding, one view.
- Continuous scans — asynchronous, even post-release.
- Contextual rescoring — patch what matters, not the noise.
- Identity-correlated evidence — auditors get answers, not spreadsheets.

WHAT OCM UNLOCKS FOR SAP

Six outcomes from one shared primitive.



Faster sovereign delivery

Pack once, ship everywhere.
Sovereign Cloud for all products.



Compliance leverage across LoBs

Report from one shared primitive —
ODG correlates all findings.



Integration after acquisition

Acquired companies converge onto one
model.



Cross-LoB security correlation

Blast radius is one query —
answered via the OCM coordinate
system.



One source of truth

One signed descriptor per delivery.
Rebuild any landscape.



Ecosystem stewardship

SAP investment compounds with
the open-peer ecosystem.

WHERE OCM IS SHIPPING — OPEN ECOSYSTEM

Peer in the open ecosystem.



Kyma



OpenControlPlane

KENFIDENCE

Aligned with **NeoNephos** Foundation 

WHERE OCM IS SHIPPING — SAP

Five SAP teams. Already running on OCM

- Hyperspace — internal Dev Portal & product delivery.
- Release-Based Shipment Channel (RBSC) — customer shipment channel.
- Common Service Infrastructure (CSI) — shared internal services platform.
- Steampunk — ABAP Development PaaS.
- Sovereign Services & Delivery — operates SAP products in sovereign clouds

Sponsor. Scale. Standardize.

Sponsor — Allocate engineering capacity to OCM stewardship in your LoB.

Scale — Pack one regulated component as an OCM component this quarter.

Standardize — Bring your LoB into the OCM steering conversation — SAP Slack #sap-tech-ocm.



APPENDIX — ABBREVIATIONS

Quick reference for the acronyms used in this deck.

BSI C5 — Bundesamt für Sicherheit in der Informationstechnik — Cloud Computing Compliance Criteria Catalogue.

BTP — SAP Business Technology Platform.

CRA — Cyber Resilience Act — EU regulation on cybersecurity for products with digital elements.

DORA — Digital Operational Resilience Act — EU regulation on ICT risk management in financial services.

FedRAMP — Federal Risk and Authorization Management Program — US standardised cloud security assessment.

FISMA — Federal Information Security Modernization Act — US federal information security mandate.

Grype — Open-source vulnerability scanner for container images and filesystems (Anchore).

Helm — Package manager for Kubernetes; reference artifact type for OCM.

LoB — Line of Business — SAP organisational unit owning a product portfolio.

NeoNephos — European foundation for sovereign cloud open-source projects, hosted under the Linux Foundation.

NIS2 — Network and Information Security Directive 2 — EU baseline for cybersecurity of essential entities.

OCI — Open Container Initiative — open standards for container image format and distribution.

OCM — Open Component Model — vendor-neutral specification for signed, transportable software components.

ODG — Open Delivery Gear — OCM-native compliance automation engine and dashboard.

OSS — Open Source Software.

PKI — Public Key Infrastructure — framework for managing certificates and signing keys.

SBOD — Software Bill of Delivery — the OCM component descriptor, signed and traceable. Containing all artifacts and metadata for delivery and deployment.

SBOM — Software Bill of Materials — inventory of components and dependencies inside a software artifact.

SecNumCloud — French cloud security qualification scheme operated by ANSSI.

Sigstore — Open-source project for keyless software signing using OIDC identities.

SPDX — Software Package Data Exchange — ISO/IEC 5962 standard format for SBOM data.

SWID — Software Identification Tags — ISO/IEC 19770-2 standard for software inventory.

Trivy — Open-source security scanner for containers, IaC, and code (Aqua Security).